

Scorr Security

Overview for Organizations

How Scorr protects your company data, people, and sessions —
written so you can share this with leadership, IT, and compliance.

Platform: <https://scorr.walfia.ai>

Document: October 5, 2026

Contact: info@walfia.ai

Audience: Company admins · IT · Security reviewers

Table of Contents

1. Executive summary
2. Security principles
3. Multi-tenant data isolation
4. Authentication & passwords
5. Multi-factor authentication (MFA)
6. Session security & idle lock
7. Role-based access control
8. Database & API protection (RLS)
9. Company onboarding controls
10. Attendance & location data
11. Demo sandbox isolation
12. Account recovery & deletion
13. Mobile apps (Android & iOS)
14. What we do not claim
15. Security checklist for your organization
16. Contact & further documents

1. Executive summary

Scorr is a multi-company performance and attendance platform. Every organization runs as a private tenant: your people, KPIs, attendance, rewards, daily reports, and GPS records are separated from every other company on the same platform.

Security is built into the product — not bolted on later. Access requires a verified login, mandatory authenticator MFA for real accounts, and database policies that enforce who can read or write each record.

In one sentence

Scorr is designed so that only authenticated users in your company, with the correct role, can see your data — over encrypted HTTPS — with MFA, rate limits, idle session lock, and company-scoped storage.

Who this document is for

- Company leadership evaluating Scorr for rollout.
- IT / security teams reviewing architecture and controls.
- HR and Admin owners who must explain “how secure is it?” to stakeholders.

2. Security principles

- Least privilege — each role sees only what the role needs (Admin, HR, Manager, Employee).
- Tenant isolation — company_id scopes data; Company A cannot query Company B.
- Defense in depth — browser/app !' HTTPS !' Auth !' role checks !' Row Level S
- Verify identity — password + MFA (TOTP) for production accounts; backup codes and email recovery when devices are lost.
- Minimize sensitive data — GPS is used for attendance check-in/out, not sold or shared across tenants.
- Audit & recovery — login attempt recording, admin authenticator reset, account deletion with owner safeguards.

3. Multi-tenant data isolation

Scorr hosts many organizations on one platform. Isolation is enforced in application logic and in the database.

3.1 How tenants are separated

- Every user and business record is tied to a `company_id`.
- Queries and RPC functions resolve the current company from the signed-in user.
- Lists (people, KPIs, attendance, reports, rewards) are filtered to that company.
- Platform-owner tools (/platform) approve companies; they are not a “super user” inside your day-to-day employee data for other orgs beyond platform operations.

3.2 What this means for you

- Your competitors on Scorr cannot open your dashboards or export your files.
- Managers only see their allowed team scope; employees only see their own records.
- HR and Admin work inside your organization boundary.

Isolation depends on correct role assignment. Train admins to assign HR / Manager / Employee carefully and keep “Reports to” accurate.

4. Authentication & passwords

4.1 Identity provider

Scorr uses Supabase Auth for sign-in. Passwords are hashed by the auth service — they are not stored as readable plain text in your company tables.

4.2 Password rules & reset

- Minimum password length: 6 characters (enforced at registration and change).
- Forgot password: rate-limited email of a temporary password (about 15 minutes cool-down when limited).
- Change password: verified through a secured server function so MFA sessions remain consistent.

4.3 Login abuse protection

- Failed sign-in attempts are recorded.
- Rate limiting blocks rapid password guessing (“Too many sign-in attempts. Wait 15 minutes…”).
- Forgot-password requests are also rate-limited.
- Generic error messages avoid revealing whether an email exists when that would help attackers.

Control	Purpose
Hashed passwords	Credential theft from DB does not expose clear passwords.
Login rate limit	Slows brute-force attacks.
Forgot-password limit	Stops reset email flooding.
HTTPS only	Credentials and tokens travel encrypted in transit.

5. Multi-factor authentication (MFA)

Production Admin, HR, Manager, and Employee accounts must enroll authenticator MFA. Demo sandbox accounts skip MFA by design.

5.1 What users enroll

- TOTP apps: Google Authenticator or Microsoft Authenticator (industry-standard time-based codes).
- After enrollment, users receive 10 one-time backup codes (format like ABCD-EFGH).
- Backup codes are burned after use — store them offline.

5.2 Daily login

- Password (first factor) + authenticator code (second factor), or
- Password + one unused backup code if the phone is unavailable.

5.3 Lost device recovery

- Email OTP recovery path (time-limited) to verify the user, then re-enroll a new authenticator.
- Optional recovery email under Settings !' Account security.
- Company Admin can Reset authenticator from People for a locked-out teammate (privileged action).

MFA raises the bar significantly: a stolen password alone is not enough to open the dashboard for production accounts.

6. Session security & idle lock

6.1 Session model

- After successful auth + MFA, Scorr issues a session for the browser or native app.
- Sessions are bound to the authenticated user; API calls use that identity (`auth.uid()`).

6.2 Idle auto-logout

- If there is no user activity for 60 minutes, the portal locks / signs out.
- Activity includes normal interaction (mouse, keyboard, touch).
- This reduces risk on shared or unattended office devices.

6.3 Practical guidance for organizations

- Require staff to lock phones and laptops when away from desk.
- Do not share login credentials between people — create one account per person.
- Revoke access promptly in People when someone leaves the company.

7. Role-based access control

Scorr enforces four company roles. The UI and server both respect the role.

Role	Security-relevant access
Admin	Full company configuration: people, departments, offices, tasks, rewards, attendance oversight, exports, branding. Approves manager/HR leave; receives HR/manager daily-report alerts.
HR	Company operations console; must report to a company admin. Own attendance + daily report go to admin. Cannot bypass tenant isolation.
Manager	Department/team scope: assign KPIs, approve employee leave/gifts, own attendance and daily report.
Employee	Own KPIs, attendance, leave requests, daily report, gift redeem — no company-wide admin tools.

Why this matters

- A compromised employee password (even with MFA bypass attempts) still cannot manage the whole org.
- Managers cannot see unrelated departments outside their allowed scope.
- Privilege changes are controlled by Admin in People.

8. Database & API protection (RLS)

8.1 Row Level Security

PostgreSQL Row Level Security (RLS) is enabled on core tables (users, KPIs, notifications, attendance-related data, and other business tables). Policies typically allow:

- A user to read/update their own rows.
- A manager to access their team where `is_manager_of` applies.
- Admin/HR (company privileged roles) to manage within the company.

8.2 Security-definer functions

- Sensitive operations run through controlled SQL functions (SECURITY DEFINER) that still check `auth.uid()`, role, and company.
- Examples: attendance geo processing, leave submit/review, daily report submit, user updates, office assignment.
- Clients cannot freely rewrite another company's tables through the public API.

8.3 Edge functions for privileged actions

- Password change, forgot password, MFA recovery, authenticator reset, account deletion, and similar flows run as server-side edge functions.
- These keep privileged Auth Admin operations off the browser.

Even if someone tampers with the UI, the database policies and RPCs are the source of truth for authorization.

9. Company onboarding controls

9.1 Registration is not instant full access

- Register Company collects account + company details.
- Email verification OTP (6 digits) confirms the registrant owns the inbox.
- Status becomes awaiting platform approval — dashboard stays closed until approved.
- Walfia platform owner reviews at /platform (Approve / Reject / Pause).
- Trial starts on approval — reduces fake or abusive signups.

9.2 Ongoing company status

- Paused / suspended / rejected companies cannot use the product normally.
- Contact info@walfia.ai for account status issues.

10. Attendance & location data

10.1 What is collected

- GPS coordinates at clock-in and clock-out (and related attendance processing) for Office / Hybrid modes.
- Shift times, present/absent marks, leave requests, and visit segments for multi-visit days.
- Remote staff may be marked by supervisors without GPS.

10.2 How it is protected

- Location APIs require a secure context (HTTPS) — e.g. <https://scorr.walfia.ai>.
- Attendance records are company-scoped; other tenants cannot read them.
- Managers see team-relevant attendance; employees see their own history.
- Scorr does not sell location data and does not expose it to other organizations.

10.3 Organizational recommendations

- Publish an internal policy: when GPS is required and why.
- Assign Office GPS zones only to people who need them.
- Use Remote/Hybrid work modes when GPS is not appropriate.

11. Demo sandbox isolation

Public demo accounts (?demo=1) exist for product trials. They are isolated from production companies.

- Demo users are flagged is_demo.
- enforce_demo_isolation prevents demo sessions from touching real company users.
- Demo admins cannot provision real production staff.
- MFA is skipped only for demo — never for real company accounts.

Always evaluate security using a real approved company account, not the public demo personas.

12. Account recovery & deletion

12.1 Recovery

- Forgot password !' rate-limited temporary password email.
- MFA email recovery + backup codes + admin authenticator reset.
- Settings !' Account security: regenerate backup codes, set recovery email, v available.

12.2 Account deletion

- Self-serve: Settings !' Delete my account (type DELETE + password).
- Help page: <https://scorr.walfia.ai/delete-account>
- Company owners with remaining members must transfer ownership or confirm full company deletion — prevents accidental wipe of a live org.
- Email info@walfia.ai for assisted requests (handled within stated support window).

13. Mobile apps (Android & iOS)

- Android APK and iPhone Home Screen / native shell use the same Scorr backend and auth.
- Same MFA, roles, and company isolation as the website.
- Store/download CTAs are hidden inside the already-installed app.
- Location permission is requested for attendance — grant “while using the app” for GPS modes.
- Keep devices updated; install APKs only from <https://scorr.walfia.ai/#download-app> (official source).

Do not sideload Scorr APKs from unknown websites. Official download: scorr.walfia.ai.

14. What we do not claim

Transparency builds trust. This brief describes product and platform controls as implemented in Scorr. It is not a substitute for your own legal, privacy, or compliance review.

- This document does not assert a specific third-party certification (for example SOC 2 or ISO 27001) unless Walfia has separately provided that certificate to you.
- Security is shared: strong MFA and access hygiene on your side remain essential.
- No system can guarantee zero risk; Scorr reduces risk through layered controls.
- For contracts, DPAs, or region-specific residency requirements, contact info@walfia.ai.

15. Security checklist for your organization

Before go-live

- Approve only real company admins; complete MFA enrollment for every production user.
- Create departments; assign Managers and Employees with correct Reports to lines.
- Set Work location (Office / Remote / Hybrid) per person.
- Configure Office GPS only where needed; communicate the attendance policy.
- Train staff: never share passwords; store backup codes offline.

Ongoing

- Offboard leavers the same day in People (or reset password / remove access).
- Review Admin/HR privileges quarterly.
- Monitor Daily Reports and leave approvals for unusual patterns.
- Keep Android/iOS builds current from the official download page.
- Escalate suspected account takeover to info@walfia.ai immediately.

16. Contact & further documents

Resource	Where
Live product	https://scorr.walfia.ai
This security PDF	https://scorr.walfia.ai/downloads/Scorr-Security-Overview.pdf
Full user guide PDF	https://scorr.walfia.ai/downloads/Scorr-Client-Feature-Guide.pdf
App download	https://scorr.walfia.ai/#download-app
Delete-account help	https://scorr.walfia.ai/delete-account
Support	info@walfia.ai

Scorr is built so organizations can run KPIs, attendance, and rewards with clear boundaries: one company, authenticated people, verified MFA, and database-enforced access. Share this brief with your IT and leadership teams when evaluating or rolling out Scorr.

© Walfia · <https://scorr.walfia.ai> · info@walfia.ai

Document generated: October 5, 2026